AEGIS BANK

Incident Response Plan

Enterprise AI Decision & Knowledge Platform for Modern Banking

---

Document Information

Field	Details
Document Title	Cyber Security Incident Response Plan
Document ID	**AB-SEC-004**
Department	Information Security
Version	v1.2
Last Updated	July 24, 2026
Document Owner	Security Operations Center (SOC)
Classification	Restricted
Review Date	July 24, 2027
Approved By	**Sami Khan – Chief Executive Officer (CEO)**

Confidentiality Notice

This Incident Response Plan defines the procedures, responsibilities, and communication processes used by Aegis Bank to detect, contain, investigate, and recover from cybersecurity incidents.

This document contains restricted operational security information and may only be accessed by authorized personnel.

Unauthorized disclosure is prohibited.

Table of Contents

1. Purpose

2. Scope
3. Incident Response Principles
4. Incident Classification
5. Incident Response Team
6. Incident Lifecycle
7. Detection & Reporting
8. Containment Procedures
9. Investigation & Analysis
10. Eradication Process
11. Recovery Procedures
12. Post-Incident Review
13. Communication Management
14. Practical Examples
15. FAQs
16. Revision History
17. Document Approval

---

1. Purpose

The purpose of this Incident Response Plan is to establish a structured approach for managing cybersecurity incidents affecting Aegis Bank systems, customer information, and business operations.

The plan ensures:

- Rapid incident detection.
- Effective containment.
- Reduced business impact.
- Protection of customer data.
- Regulatory compliance.

- Faster recovery.
- Continuous improvement.

---

2. Scope

This plan applies to:

- Employees
- Security Operations Center (SOC)
- IT Operations
- Infrastructure Teams
- Application Teams
- Compliance Department
- Legal Department
- Risk Management
- Third-party service providers

It covers incidents involving:

- Malware attacks.
- Data breaches.
- Unauthorized access.
- Phishing attacks.
- Ransomware.
- Insider threats.
- System compromise.
- Account takeover.
- Cloud security incidents.
- Application vulnerabilities.

---

3. Incident Response Principles

Aegis Bank follows these core principles:

Preparation

Maintain security tools, procedures, and trained personnel.

Detection

Identify suspicious activities through monitoring systems.

Containment

Limit the impact and prevent further damage.

Investigation

Determine the cause, scope, and affected assets.

Recovery

Restore systems safely and return operations to normal.

Improvement

Update controls based on lessons learned.

---

4. Incident Classification

Security incidents are categorized according to severity.

Severity	Description	Example
Critical	Severe impact on banking operations or customer data	Major data breach, ransomware attack
High	Significant security risk requiring urgent response	Privileged account compromise
Medium	Limited impact requiring investigation	Malware infection on single device
Low	Minor security event	Suspicious email report

---

5. Incident Response Team

The Incident Response Team (IRT) is responsible for managing cybersecurity incidents.

Chief Information Security Officer (CISO)

Responsibilities:

- Provides strategic direction.
- Approves major response decisions.
- Coordinates executive communication.

Security Operations Center (SOC)

Responsibilities:

- Detects security events.
- Investigates alerts.
- Performs initial analysis.
- Coordinates technical response.

IT Operations Team

Responsibilities:

- Performs system isolation.
- Restores affected services.
- Applies security fixes.

Compliance Department

Responsibilities:

- Reviews regulatory obligations.
- Coordinates required reporting.
- Maintains compliance records.

Legal Department

Responsibilities:

- Provides legal guidance.
- Reviews notification requirements.
- Supports investigations.

---

6. Incident Response Lifecycle

Every security incident follows six phases:

Preparation

↓

Detection

↓

Containment

↓

Investigation

↓

Recovery

↓

Lessons Learned

---

7. Detection & Reporting

Security incidents may be detected through:

- SIEM alerts.
- Endpoint security systems.
- Employee reports.
- Customer complaints.

- Threat intelligence.
- Network monitoring.
- Fraud detection systems.

Employees must immediately report:

- Suspicious emails.
- Unauthorized access attempts.
- Lost devices.
- Malware warnings.
- Data exposure concerns.

---

8. Initial Response Procedure

When an incident is identified:

1. Create an incident ticket.
2. Record time and affected systems.
3. Assign severity level.
4. Notify responsible teams.
5. Begin investigation.
6. Preserve evidence.

All incident activities must be documented.

---

9. Containment Procedures

Containment aims to prevent further damage.

Actions may include:

- Blocking malicious IP addresses.
- Disabling compromised accounts.
- Isolating infected devices.

- Restricting network access.
- Blocking suspicious transactions.
- Applying temporary security controls.

Emergency actions may be taken to protect critical banking services.

---

10. Investigation & Analysis

The Security Team investigates:

- Attack source.
- Affected systems.
- Data exposure.
- User accounts involved.
- Malware behavior.
- Timeline of events.
- Security control failures.

Evidence must be collected and preserved according to forensic procedures.

---

11. Eradication Process

After investigation:

- Remove malicious software.
- Close vulnerabilities.
- Reset compromised credentials.
- Apply security patches.
- Improve security controls.
- Validate system security.

Systems must not return to production until security approval is obtained.

---

12. Recovery Procedures

Recovery activities include:

- Restoring affected services.
- Monitoring systems closely.
- Confirming security controls.
- Validating data integrity.
- Communicating operational status.

Critical banking systems require additional approval before restoration.

---

13. Post-Incident Review

After every significant incident, Aegis Bank performs a review.

The review evaluates:

- Root cause.
- Response effectiveness.
- Business impact.
- Security gaps.
- Required improvements.

Actions may include:

- Policy updates.
- Additional training.
- Technology improvements.
- Process changes.

---

14. Communication Management

Incident communication must be controlled.

Only authorized personnel may communicate with:

- Customers.
- Regulators.
- Media.
- External parties.

Employees must not publicly discuss security incidents without approval.

15. Data Breach Response Procedure

A data breach occurs when unauthorized individuals gain access to, disclose, modify, or steal confidential information.

Examples include:

- Customer data exposure.
- Unauthorized database access.
- Lost devices containing sensitive information.
- Employee accidental data disclosure.
- External cyber attacks.

Data Breach Response Steps

Step 1 – Identification

The Security Operations Center (SOC) identifies:

- Type of data affected.
- Systems involved.
- Number of impacted users.
- Source of the breach.

Step 2 – Containment

Immediate actions may include:

- Blocking unauthorized access.
- Disabling compromised accounts.
- Isolating affected systems.
- Preserving evidence.
- Preventing additional data loss.

Step 3 – Assessment

The Incident Response Team evaluates:

- Nature of exposed information.
- Customer impact.
- Regulatory requirements.
- Business impact.
- Security control failures.

Step 4 – Notification

Where required, Aegis Bank shall notify:

- Regulatory authorities.
- Customers.
- Business partners.
- Internal stakeholders.

Notifications must be approved by Compliance and Legal teams.

Step 5 – Recovery

Recovery activities include:

- Restoring secure operations.
- Validating system integrity.

- Monitoring for additional threats.
- Implementing preventive controls.

---

16. Ransomware Response Procedure

Ransomware incidents require immediate action due to their potential impact on banking operations.

If ransomware is detected:

1. Disconnect affected systems from the network.
2. Do not attempt unauthorized recovery actions.
3. Notify the Security Operations Center.
4. Preserve forensic evidence.
5. Identify affected systems.
6. Activate recovery procedures.
7. Restore services from verified backups.

Ransomware Prevention Controls

Aegis Bank maintains:

- Regular backups.
- Endpoint protection.
- Network segmentation.
- Email security controls.
- Employee awareness training.
- Vulnerability management.
- Access control monitoring.

---

17. Account Compromise Response

A compromised account may indicate unauthorized access or credential theft.

Examples:

- Stolen passwords.
- Unauthorized login attempts.
- Suspicious MFA requests.
- Unusual user activity.

Response Actions

The Security Team may:

- Temporarily disable the account.
- Force password reset.
- Revoke active sessions.
- Review login history.
- Analyze user activity.
- Re-enable access after verification.

---

18. Third-Party Security Incident Handling

Third-party vendors must immediately report security incidents affecting Aegis Bank data or systems.

Vendor incident handling includes:

- Incident notification.
- Risk assessment.
- Investigation coordination.
- Evidence collection.
- Impact analysis.
- Corrective action tracking.

High-risk vendor incidents require review by:

- Information Security.
- Compliance.
- Risk Management.
- Legal Department.

---

19. Incident Documentation Requirements

Every security incident must maintain complete records.

Incident records should include:

Field	Description
Incident ID	Unique tracking number
Date & Time	Detection and response timeline
Severity	Critical, High, Medium, Low
Description	Summary of incident
Affected Systems	Impacted assets
Investigation Notes	Technical findings
Actions Taken	Response activities
Root Cause	Reason behind incident
Resolution	Final outcome
Lessons Learned	Improvement actions

---

20. Practical Examples

Example 1 – Phishing Attack

An employee receives a phishing email and enters credentials on a fake banking website.

Response:

- Employee reports the incident.
- Security Team investigates login activity.
- Account sessions are revoked.
- Password reset is forced.
- MFA verification is reviewed.
- Awareness training is provided.

Example 2 – Database Breach Attempt

Security monitoring detects unusual database access from an unknown location.

Response:

- Access is blocked.
- Database logs are analyzed.
- User accounts are reviewed.
- Vulnerability assessment is performed.
- Security controls are strengthened.

Example 3 – Ransomware Detection

An employee notices files becoming encrypted unexpectedly.

Response:

- Device is isolated from the network.
- SOC is notified.
- Malware analysis begins.
- Backup restoration process is initiated.
- Root cause investigation is completed.

Example 4 – Lost Employee Laptop

A company laptop containing confidential information is lost.

Response:

- Device access is disabled.
- Remote wipe capability is activated where available.
- Access credentials are reviewed.
- Incident impact is assessed.
- Security report is created.

---

21. Frequently Asked Questions (FAQs)

Q1. What should employees do if they suspect a cyber incident?

Employees must immediately report the incident to the Information Security Team and avoid taking unauthorized actions.

Q2. Who manages cybersecurity incidents?

The Incident Response Team, led by Information Security, manages cybersecurity incidents with support from IT, Compliance, and Legal teams.

Q3. Should employees investigate incidents themselves?

No. Employees should report incidents and allow authorized security personnel to perform investigations.

Q4. How quickly should incidents be reported?

Security incidents must be reported immediately after detection.

Q5. What happens after an incident is resolved?

A post-incident review is conducted to identify improvements and prevent future occurrences.

Q6. Are customers informed about security incidents?

Where required by law or regulation, customer notifications are managed through approved communication procedures.

---

22. Related Documents

This plan should be read together with:

- Password Policy (AB-SEC-001)
- Multi-Factor Authentication Policy (AB-SEC-002)
- Cyber Security Policy (AB-SEC-003)
- Data Classification Policy (AB-SEC-005)
- Disaster Recovery Plan (AB-DR-002)
- Business Continuity Plan (AB-DR-003)
- Backup Strategy (AB-DR-001)

---

23. Revision History

Version	Date	Description	Author
v1.0	January 25, 2026	Initial Release	Security Operations Center
v1.1	April 22, 2026	Added Data Breach and Ransomware Response Procedures	Security Operations Center
v1.2	**July 24, 2026**	**Enhanced Incident Classification, Recovery Procedures, and Third-Party Incident Handling**	**Security Operations Center**

---

24. Document Approval

Field	Details
Document ID	**AB-SEC-004**
Document Title	**Cyber Security Incident Response Plan**
Department	Information Security
Version	**v1.2**
Classification	**Restricted**
Document Owner	Security Operations Center (SOC)
Approved By	**Sami Khan – Chief Executive Officer (CEO)**
Approval Date	**July 24, 2026**
Next Review Date	**July 24, 2027**

Document Control

Attribute	Value
Document Status	Approved
Distribution	SOC, Information Security, IT Operations, Compliance, Legal, Risk Management
Language	English
Storage Location	Aegis Bank Document Management System (DMS)
Retention Period	7 Years
Supersedes	Incident Response Plan v1.1

End of Document

Aegis Bank
Enterprise AI Decision & Knowledge Platform for Modern Banking

© 2026 Aegis Bank. All Rights Reserved.